



PROS-NC-005

PROCEDIMIENTO MONITOREO DEL USO DE LOS MEDIOS DE PROCESAMIENTO DE INFORMACION

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v04 – Octubre del 2019

	Responsable	Fecha	Firma
Elaborado	Rodrigo Vidal / Encargado PMG SSI	Octubre 2019	
Revisado	José Villa / Área Seguridad de la Información (Representante Comité de Seguridad)	Octubre 2019	
Aprobado	Gabriel Reveco / Encargado Ciberseguridad (Presidente Comité de Seguridad de la Información)	Octubre 2019	



Contenido

1	PROPÓSITO	3
2	ALCANCE	3
3	TERMINOLOGÍA.....	3
4	DOCUMENTOS APLICABLES	4
5	ROLES Y RESPONSABILIDADES	4
6	PROCEDIMIENTO.....	4
6.1	Monitoreo y gestión de la capacidad de los medios de procesamiento de información.	4
6.1.1	Monitoreo de Servidores	4
6.1.2	Monitoreo del estado de los servicios y aplicaciones	4
6.1.3	Monitoreo de vulnerabilidades y verificación del cumplimiento técnico.....	5
6.1.4	Gestión de eventos o incidentes de seguridad:.....	5
6.2	Registros del administrador y del operador.....	6
6.3	Sincronización con los relojes	7
7	REGISTROS.....	7
8	DIFUSION	7
9	REVISION Y MEDICION	7
10	CONTROL DE VERSIONES	7

1 PROPÓSITO

Definir las actividades para monitorear el uso de las instalaciones de procesamiento de la información de Minsal en el Nivel Central.

2 ALCANCE

Este procedimiento es aplicable a todos los funcionarios¹ (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para las Subsecretarías de Salud Pública y de Redes Asistenciales y que tengan derechos de acceso a la información que puedan afectar los activos de información del Ministerio de Salud.

Este procedimiento abarca los siguientes controles definidos en la norma NCh-ISO 27001.Of2013:

- A.12.04.01 Registro de evento
- A.12.04.03 Registros del administrador y el operador
- A.12.04.04 Sincronización de relojes
- A.12.06.01 Gestión de las vulnerabilidades técnicas
- A.18.02.03 Verificación del cumplimiento técnico

3 TERMINOLOGÍA

MINSAL: Ministerio de Salud.

SGSI: Sistema de Gestión de Seguridad de Información.

DNS: Sistema de nombres de dominio.

CPU: unidad central de procesamiento.

Streaming: es la distribución digital de contenido multimedia a través de una red de computadoras, de manera que el usuario utiliza el producto a la vez que se descarga.

ID: cuenta de usuario, identificador.

Gateway: puerta de enlace, dispositivo que actúa de interfaz de conexión entre aparatos o dispositivos, y también posibilita compartir recursos entre dos o más computadoras.

Firewall: cortafuegos, dispositivo o conjunto de dispositivos configurados para permitir, limitar, cifrar, descifrar, el tráfico entre los diferentes ámbitos sobre la base de un conjunto de normas y otros criterios.

Cloud computing: es un modelo para permitir el acceso adecuado y bajo demanda a un conjunto de recursos de cómputo configurables (p.e. redes, servidores, almacenamiento, aplicaciones y servicios) que pueden ser rápidamente provistos y puestos a disposición del cliente con un mínimo esfuerzo de gestión y de interacción con el proveedor del servicio.

RAM: memoria de acceso aleatorio.

¹ A lo largo del procedimiento cada vez que se mencione funcionario se refiere a: funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.).

4 DOCUMENTOS APLICABLES

- NCh-ISO27001.Of2013 Tecnología de la información – Técnicas de seguridad – Sistemas de gestión de la seguridad de la información – Requisitos.
- Procedimiento de desarrollo seguro.
- NIST Special Publication 800-92 Guide to Computer Security Log Management.
- Procedimiento gestión de incidentes de seguridad de la información.
- Política de Desarrollo de Sistemas.

5 ROLES Y RESPONSABILIDADES

- **Operaciones TIC**

Es responsable del monitoreo de la capacidad de los servidores, servicios y aplicaciones existentes en producción y además el monitoreo del uso de los Equipos de comunicación.

6 PROCEDIMIENTO

6.1 Monitoreo y gestión de la capacidad de los medios de procesamiento de información.

6.1.1 Monitoreo de Servidores

El área de Operaciones TIC debe contar con herramientas para monitorear, a lo menos una vez a la semana, los servidores que tenga bajo su administración, y mantener el registro electrónico de los resultados a lo menos dos años.

El monitoreo a los servidores debe incluir como mínimo:

- Porcentaje de uso de la CPU
- Espacio disponible en Disco Duro
- Memoria RAM

Cuando cualquiera de las tres variables mencionadas sobrepase el 80% de su capacidad, el Encargado del Área de Operaciones utilizará la información histórica del uso del(os) servidor(es), para evaluar el aumento de la capacidad o la reducción de la demanda. Algunas medidas para la reducción de la demanda son:

- a) eliminación de datos obsoletos (espacio en el disco);
- b) sacar de servicio a las aplicaciones, sistemas, bases de datos o entornos;
- c) eliminación de los procesos y programaciones de parches;
- d) optimización de las consultas de lógicas de aplicaciones o bases de datos;
- e) otras alternativas de almacenamiento, como Hosting o VPS (Virtual Private Server).

6.1.2 Monitoreo del estado de los servicios y aplicaciones

El área de Operaciones TIC debe contar con herramientas para monitorear a lo menos una vez a la semana los servicios que tenga bajo su administración, y mantener el registro electrónico de los resultados a lo menos dos años.

Los servicios mínimos que se deben monitorear son:

- DNS
- Video conferencia
- Internet
- Telefonía
- Wireless
- Firewall
- Aplicativos críticos.

6.1.3 Monitoreo de vulnerabilidades y verificación del cumplimiento técnico

El área de Operaciones TIC deberá contar con herramientas para monitorear de forma aleatoria las vulnerabilidades tanto en la infraestructura tecnológica como en los aplicativos que tenga a su cargo, y mantener el registro electrónico de los resultados a lo menos por dos años.

Para lo anterior se realizarán pruebas de seguridad, las que se podrán determinar usando herramientas especializadas o de manera manual. Junto con ello, la generación de un informe detallado con los resultados obtenidos durante todo el proceso de ejecución de las pruebas, con el correspondiente análisis de dicha información para poder ser interpretada de manera correcta y entender las implicaciones a nivel de seguridad sobre la infraestructura o aplicativos analizados, con las recomendaciones necesarias para solucionar dichos problemas.

6.1.4 Gestión de eventos o incidentes de seguridad:

Durante el monitoreo pueden surgir eventos que pongan en riesgo la seguridad de la información, en estos casos se debe reportar el incidente de acuerdo a lo definido en el “Procedimiento gestión de incidentes de seguridad de la información”. Algunos eventos que podrían requerir investigación adicional son:

- Pérdida de servicio, de equipos o de instalaciones.
- Mal funcionamiento o sobrecargas del sistema.
- Errores humanos.
- No cumplimiento con políticas o pautas.
- Cambios de sistema no controlados.
- Mal funcionamiento de software o hardware.
- Violaciones de acceso.
- Exposición de información sensible

Algunos elementos que pueden ser investigados en estos casos son:

- a) Acceso no autorizado:
 - identificación (ID) de usuario.
 - fecha y hora de acontecimientos claves.
 - tipos de eventos.
 - archivos accedidos.
 - programa/utilitario utilizado.
- b) Operaciones privilegiadas, tales como:
 - empleo de cuentas privilegiadas, por ejemplo, supervisor, raíz (root), administrador.
 - arranque y apagado del sistema.
 - conexión/desconexión de dispositivos de entrada-salida (I/O).
- c) Intentos de acceso no autorizados, tales como:
 - acciones de usuario fallidas o rechazadas.
 - acciones fallidas o rechazadas que implican datos y otros recursos.
 - violaciones de política de acceso y notificaciones para puertas de enlace (Gateway) y cortafuego (firewall) de red.
 - alerta de sistemas de detección de intrusión propietarios.
- d) Alertas o fallas del sistema, tales como:
 - alarmas o mensajes de consola.
 - excepciones del registro del sistema.
 - gestión de alarmas de red.
 - alarmas levantadas por el sistema de control de acceso.
- e) Cambios o intentos de cambiar, configuraciones y controles de seguridad del sistema.
- f) Descargas masivas de información.
- g) Barrido de puertos.
- h) Accesos fuera de horario habitual.
- i) Accesos con derechos de administrador.
- j) Frecuencias anormales de uso del sistema.
- k) Envío de información a servidores externos.
- l) Tráfico cifrado.
- m) Descargas de servidores externos.

6.2 Registros del administrador y del operador

Dado que los usuarios con privilegios pueden manipular los registros en las instalaciones de procesamiento de información bajo su control directo, éstas cuentas deberán ser revisadas al menos cada 12 meses mediante alguna de las siguientes:

- Auditorías internas.

- Auditorías externas.
- Revisión del encargado de Seguridad de la Información / Ciberseguridad.
- Área de Operaciones TIC (Seguridad TIC).

6.3 Sincronización con los relojes

El área de Operaciones TIC, es responsable de la sincronización de los relojes de los sistemas de procesamiento de información que tiene bajo su administración, esta sincronización se realizará a través de las siguientes herramientas:

- Parche de hora de Microsoft.
- Active Directory.
- De forma “manual” para el equipamiento que posea otro sistema operativo.

La hora de referencia que se utilizará será la proporcionada por el Servicio Hidrográfico y Oceanográfico de la Armada.

7 REGISTROS

- Registros Monitoreo de Servidores.
- Registros Monitoreo del estado de los servicios y aplicaciones.
- Registros Monitoreo de vulnerabilidades.

8 DIFUSION

La comunicación del presente procedimiento se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

9 REVISION Y MEDICION

El presente procedimiento deberá ser revisado a lo menos cada dos años o cuando ocurran cambios significativos para asegurar su continua idoneidad, eficiencia y efectividad.

10 CONTROL DE VERSIONES

Versión	Fecha de Aprobación	Motivo del cambio	Secciones modificadas
01	Diciembre 2013	Creación del documento	Todas
02	Octubre 2014	Actualización de los roles y responsabilidades en el monitoreo	6.1 Supervisión 6.2 Revisión

03	Noviembre 2016	Actualización de la normativa de referencia. Se incluyen los controles de registros de administrador y sincronización de relojes.	6.1 Monitoreo y gestión de la capacidad de los medios de procesamiento de información 6.2 Registros del administrador y del operador 6.3 Sincronización con los relojes
04	Octubre 2019	Actualización del documento.	Todas